Generally, states can be said to adopt either a basic or an enhanced definition of personal information. A typical example of a basic definition specifies personal information as the customer name linked to one or more pieces of nonpublic information such as Social Security number, driver's license number (or other state identification number), or financial account number together with any required credentials to permit access to said account.[531] A typical enhanced definition includes additional types of nonpublic information that trigger the notification requirement; examples include: passport number, military identification number, or other unique identification number issued on a government document commonly used to verify the identity of a specific individual; unique biometric data generated from measurements or technical analysis of human body characteristics, such as a fingerprint, retina, or iris image, used to authenticate a specific individual.[532] Enhanced definitions also trigger notification requirements when a username or email address in combination with a password or security question and answer that would permit access to an online account is compromised.[533] Most states (37) adopt some form of enhanced definition, while a minority (14) adopt a basic definition.

One commenter stated that all states provided an exception to the notification requirement if the data compromised were encrypted.[534] We found that states may include an

---

notification requirements in Florida (Fla. Stat. § 501.171) and New York (N.Y. Gen. Bus. Law § 899-AA) triggered by unauthorized access to personal information. "States" in this discussion includes the 50 U.S. states and the District of Columbia, for a total of 51. All state law citations are to the Sept. 2023 versions of state codes.

531 *See, e.g.*, Kan. Stat. § 50-7a01(g) or Minn. Stat. § 325E.61(e).

532 *See, e.g.*, Md. Comm. Code § 14-3501 (defining "personal information" to include credit card numbers, health information, health insurance information, and biometric data such as retina or fingerprint).

533 *See, e.g.*, Ariz. Code § 18-551 (defining "personal information" to include an individual's username or email address, in combination with a password or security question and answer, that allows access to an online account).

534 *See* SIFMA Comment Letter 2 ("Note that all U.S. state data breach notification laws provide an encryption

explicit encryption or redaction exception in their definition of personal information,[535] in their definition of breach,[536] or in the determination that notification of affected individuals is necessary.[537] Multiple states include at least two of these exceptions. States vary, however, in the whether and how they define encryption or redaction.[538]

Most states (43) provide an exception to the notification requirement if, following a breach of security, the entity investigates and determines that there is no reasonable likelihood that the individual whose personal information was breached has experienced or will experience certain harms ("no-harm exception").[539] Twenty of these states do not have a presumption of notification and instead require notification only if, for example, an investigation reveals a risk of harm or misuse.[540] Although the types of harms vary by state, they most commonly include: "harm" generally (13), identity theft or other fraud (10), or misuse of personal information (8). Figure 1 plots the frequency of the various types of harms referenced in states' no-harm exceptions.

---

safe harbor."); *see also* Liisa M. Thomas, THOMAS ON DATA BREACH: A PRACTICAL GUIDE TO HANDLING DATA BREACH NOTIFICATIONS WORLDWIDE (Feb. 2023), at § 2:45 ("Thomas 2023").

535 *See, e.g.*, Kan. Stat. § 50-7a01(g) (defining "personal information" to include a consumer's first name or first initial and last name linked to any one or more of the specified data elements that relate to the consumer, when the data elements are neither encrypted nor redacted); Wyo. Stat. § 40-12-501 (defining "personal identifying information" to exclude redacted data elements).

536 *See, e.g.*, Ariz. Code § 18-551 (defining "breach" to include unauthorized acquisition of and unauthorized access that materially compromises the security or confidentiality of unencrypted and unredacted computerized personal information).

537 *See, e.g.*, Minn. Stat. § 325E.61(a) (requiring notification of a breach to any resident whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person).

538 We considered a safe harbor from the notification requirements for encrypted information. *See infra* section IV.F.3.

539 *See, e.g.*, Fla. Stat. § 501.171(4)(c) and N.Y. Gen. Bus. Law § 899-AA(2)(a). Eight states, including California and Texas, do not have a no-harm exception and require notification even in the cases where there is no risk of harm.

540 *See, e.g.*, N.C. Stat. § 75-61(14) and Utah Code 13-44-202(1).

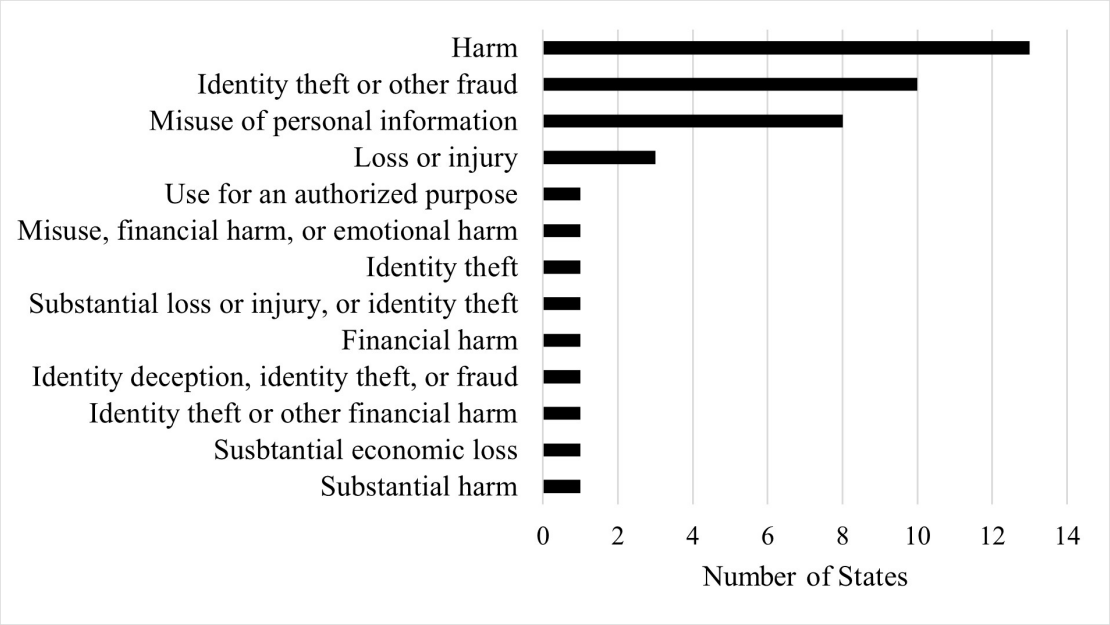


Figure 1: Frequency of types of harms referenced by state laws with no-harm exceptions to notification requirements. Data source: State law in 2023.

### *(2) Timing, Content, and Method of Notification*

In general, state laws provide a general principle for timing of notification (e.g., delivery shall be made "without unreasonable delay," or "in the most expedient time possible and without unreasonable delay").[541] Some states augment the general principle with a specific deadline (e.g., notice must be made "in the most expedient time possible and without unreasonable delay, but not later than 30 days after the date of determination that the breach occurred" unless certain exceptions apply).[542] All states allow for a delay if it is requested by a law enforcement

---

541 *See, e.g.*, Cal. Civ. Code § 1798.82(a) (disclosure to be made "in the most expedient time possible and without unreasonable delay" but allowing for needs of law enforcement and measures to determine the scope of the breach and restore the system).

542 *See, e.g.*, Colo. Rev. Stat. § 6-1-716(2)(a) (notice to be made "in the most expedient time possible and without unreasonable delay, but not later than thirty days after the date of determination that a security breach occurred, consistent with the legitimate needs of law enforcement and consistent with any measures necessary to determine the scope of the breach and to restore the reasonable integrity of the computerized data system"); Fla. Stat. § 501.171(4)(a) (notice to be made "as expeditiously as practicable and without unreasonable delay … but no later than 30 days after the determination of a breach" unless delayed at the request of law enforcement or waived pursuant to the state's no-harm exception).

agency.[543] Additionally, some states allow for a delay if necessary to determine the nature and scope of the breach or to restore the reasonable integrity of the information system.[544] Figure 2 plots the frequency of different notification deadlines in state laws. For states with specific deadlines, the figure distinguishes between states that allow an exception to determine the nature and scope of the breach or to restore the reasonable integrity of the information system, and those that do not.[545]

---

543 *See, e.g.*, Ala. Stat. § 8-38-5(c) ("If a federal or state law enforcement agency determines that notice to individuals required under this section would interfere with a criminal investigation or national security, the notice shall be delayed upon the receipt of written request of the law enforcement agency for a period that the law enforcement agency determines is necessary."); Ark. Code § 4-110-105(c) ("The notification required by this section may be delayed if a law enforcement agency determines that the notification will impede a criminal investigation."); Conn. Stat. § 36a-701b.(d) ("Any notification required by this section shall be delayed for a reasonable period of time if a law enforcement agency determines that the notification will impede a criminal investigation and such law enforcement agency has made a request that the notification be delayed."); Md. Comm. Code § 14-3504(d)(1) (notice may be delayed if "a law enforcement agency determines that the notification will impede a criminal investigation or jeopardize homeland or national security"); N.C. Stat. § 75-65(c) ("The notice required by this section shall be delayed if a law enforcement agency informs the business that notification may impede a criminal investigation or jeopardize national or homeland security, provided that such request is made in writing or the business documents such request contemporaneously in writing, including the name of the law enforcement officer making the request and the officer's law enforcement agency engaged in the investigation.").

544 *See, e.g.*, Tex. Bus. & Com. Code § 521.053 (notice to be made "without unreasonable delay and in each case not later than the 60th day after the date on which the person determines that the breach occurred, except as provided by Subsection (d) or as necessary to determine the scope of the breach and restore the reasonable integrity of the data system").

545 We conducted this supplemental analysis to help analyze and respond to comments, and also to provide additional context for our analysis of the possible effects of the final amendments. *See infra* section IV.D.1.b(2).

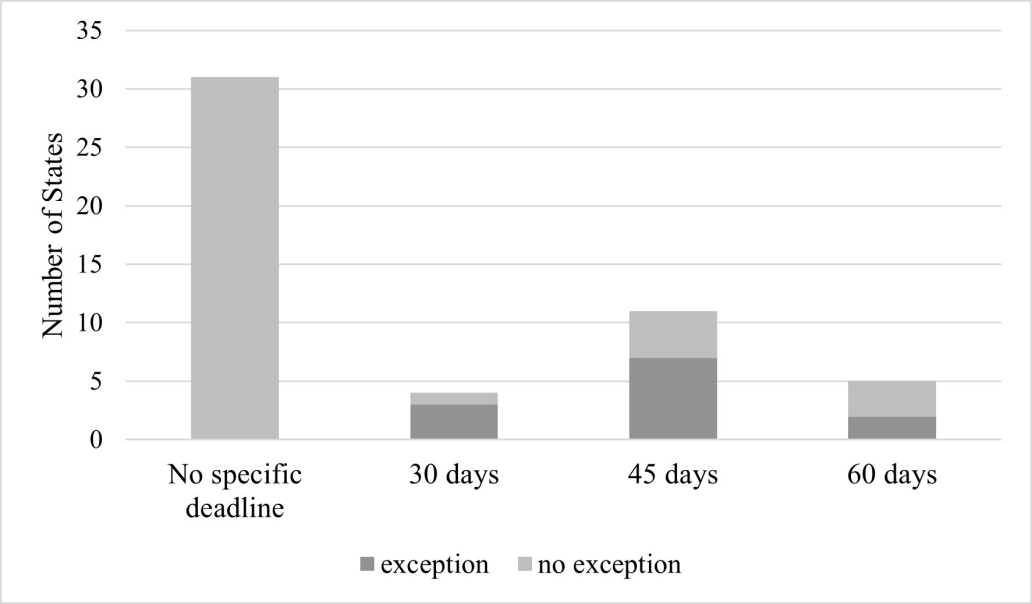


Figure 2: Frequency of notification deadlines in state laws. "Exception" states allow an exception to determine the nature and scope of the breach or to restore the reasonable integrity of the information system. Data source: State law in 2023.

One commenter stated that, where state laws have a 30-day notice requirement, the 30-day periods generally do not begin to run until a determination has been made that the incident affected residents of that state that will require notice, and that the Commission's proposed 30-day requirement would be triggered much sooner in the process.[546] The same commenter also stated that notices are currently sent to individuals whose information is reasonably believed to have potentially been affected after the findings of an investigation are determined.[547] To help analyze and respond to these comments, and also to provide additional context for our analysis of

[546] *See* CAI Comment Letter ("While the Commission correctly notes in the S-P Proposing Release that some existing state laws also include a 30-day notice requirement, those requirements generally do not begin to run until a determination has been made that the incident affected residents of that state that will require notice."). In the final amendments, as in the proposal, the beginning of the 30-day outside timeframe is a covered institution "becoming aware" that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred. *See* proposed rule 248.30(b)(4)(iii); final rule 248.30(a)(4)(iii).

[547] *See* CAI Comment Letter.

the possible effects of the final amendments,[548] we conducted supplemental analysis of the frequency of different triggers for the specific deadline requirement in the 20 states that specify such a deadline. The results of this analysis are in Figure 3 and demonstrate variation in triggering events. For example, state laws specify that the notification of customers be made "not later than sixty days from the discovery of the breach,"[549] or "no later than 30 days after the determination of a breach or reason to believe a breach occurred."[550] Many of these triggers use words such as "determination" or "confirmation," which, consistent with the commenter's observation, suggests investigation that might cause the specific deadline to be triggered later than the Commission's proposed or adopted notification trigger, although "discovery of breach"—used in five states—could potentially be earlier.[551]

---

548 *See infra* section IV.D.1.b(2).

549 *See* La. Rev. Stat. § 51:3074.

550 *See* Fla. Stat. § 501.171(4)(a).

551 *See infra* section IV.D.1.b(2).

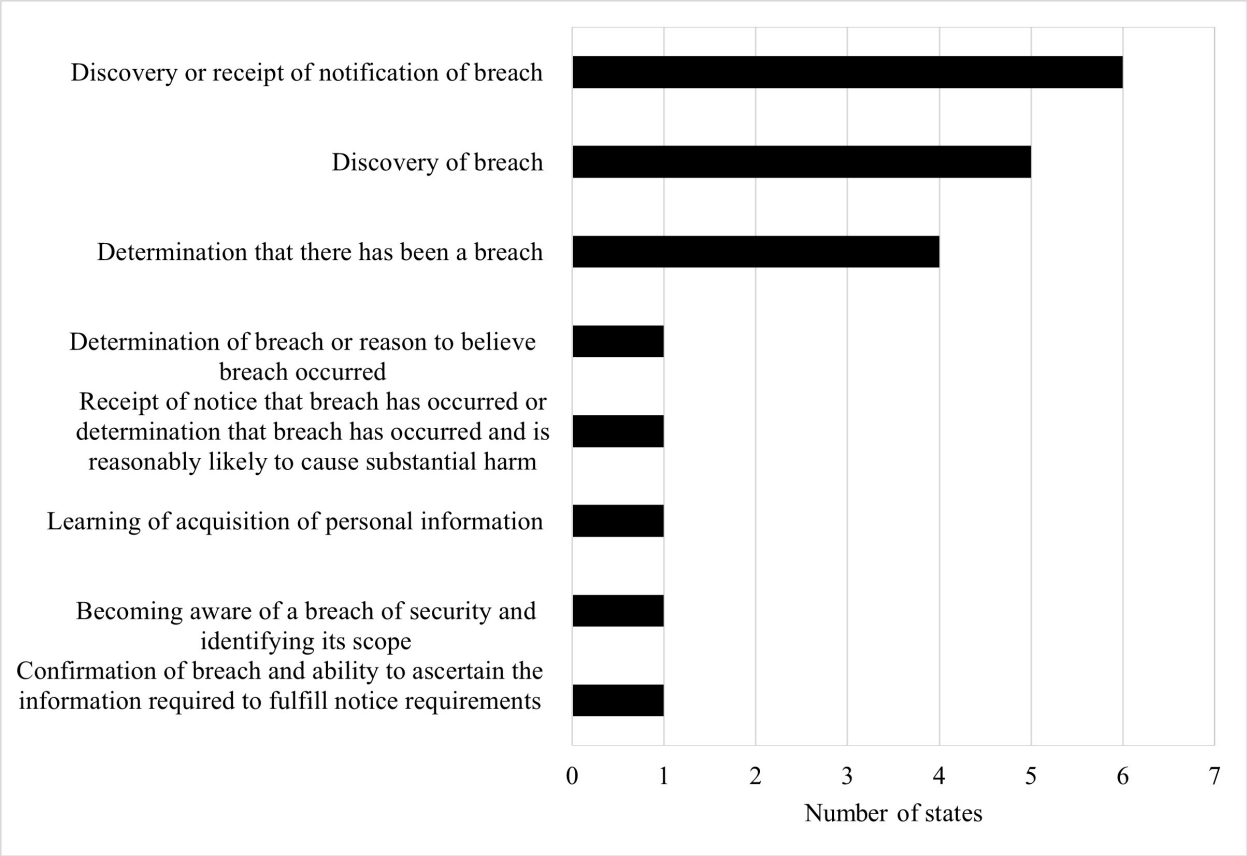


Figure 3: Frequency of triggers of notification deadline, for the 20 states that specify such a deadline. Data source: State law in 2023.

One commenter stated that most state data breach notification laws did not specify a number of days to report a breach, and that of the states that did have a specific timeframe, many had an exception allowing for compliance with the GLBA in lieu of adherence to their timeframes.[552] To help analyze and respond to this comment, and also to provide additional context for our analysis of the possible effects of the final amendments, we conducted supplemental analysis of the overlap between states that have a specific deadline and states that

[552] *See* SIFMA Comment Letter 2.

include a GLBA exception.[553] We found that of the 20 states that have a specific deadline, 10 do not include a GLBA exception.[554]

Additionally, one commenter stated the establishment of a Federal minimum standard for data breach notification would satisfy state notice laws that provide exemptions for firms subject to such a requirement.[555] To help analyze and respond to this comment, and also to provide additional context for our analysis of the possible effects of the final amendments,[556] we conducted supplemental analysis of this question. We have found that some states excuse entities from individual notification under state law if the entities comply with the notification requirements of a Federal regulator or, in some cases, another state. Some states allow these substitute notifications to replace their own state-specific requirements on notice content and timing,[557] while others only allow it if the provisions are at least as protective as state law.[558]

Some commenters stated that different state laws currently have different requirements as to what content must be included in a notice to customers.[559] One of these commenters further

---

553 *See infra* section IV.D.1.b(1).

554 We discuss this exception and the states where it applies in section IV.D.1.b(1).

555 *See* IAA Comment Letter 1.

556 *See infra* section IV.D.1.b.

557 *See*, *e.g.*, Fla. Stat. § 501.171(4)(g) ("Notice provided pursuant to rules, regulations, procedures, or guidelines established by the covered entity's primary or functional federal regulator is deemed to be in compliance with the notice requirement in this subsection …."); Va. Code. Ann. § 18.2-186.6(H) ("An entity that complies with the notification requirements … established by the entity's primary or functional state or federal regulator shall be in compliance with this section."). According to Thomas 2023, approximately 15 states allow compliance with a primary regulator to replace their own state's required notification in some circumstances; *see also* ICI Comment Letter 1 ("Today, approximately 13 states provide an exemption or exclusion from the state's breach notice requirements if the entity experiencing the breach has a duty under federal law to provide notice of the breach."). *See also infra* section IV.D.1.b(1) on GLBA safe harbor provisions, which are similar but distinct.

558 *See*, *e.g.*, Colo. Rev. Stat. 6-1-716(3)(b) ("In the case of a conflict … the law or regulation with the shortest timeframe for notice to the individual controls."); Iowa Code § 715C.2(7)(b) (exempting in the case of compliance "with a state or federal law that provides greater protection to personal information and at least as thorough disclosure requirements for breach of security or personal information than that provided by this section").

559 *See, e.g.*, IAA Comment Letter 1.

stated that, as a result, covered institutions may, when they experience a data breach incident today, send different notification letters to residents of different states for the same incident.[560] To help analyze and respond to these comments, and to provide additional context for our analysis of the possible effects of the final amendments,[561] we conducted supplemental analysis of the frequency at which different items are currently required by state laws to be included in notices to customers. This analysis, shown in Figure 4, supports commenters' observation that different states have different requirements. While half of the states do not have such requirements, many states (25) provide minimum content to be included in the notices sent to individuals whose information has been affected by a breach. The most common required items include the type of information affected, contact information for consumer reporting agencies, and the date of the breach. Figure 4 plots the frequency of different items required by state laws to be included in the notices.

---

560 *See* ICI Comment Letter 1 ("In discussing breach notices with our members, we understand it is not uncommon for their current breach response programs to include separate notification letters depending upon the state the individual resides in."). One benefit of the final amendments will be to help ensure that all customers receive a minimum level of information regarding a given breach. *See infra* section IV.D.1.b(5).

561 *See infra* section IV.D.1.b(5).

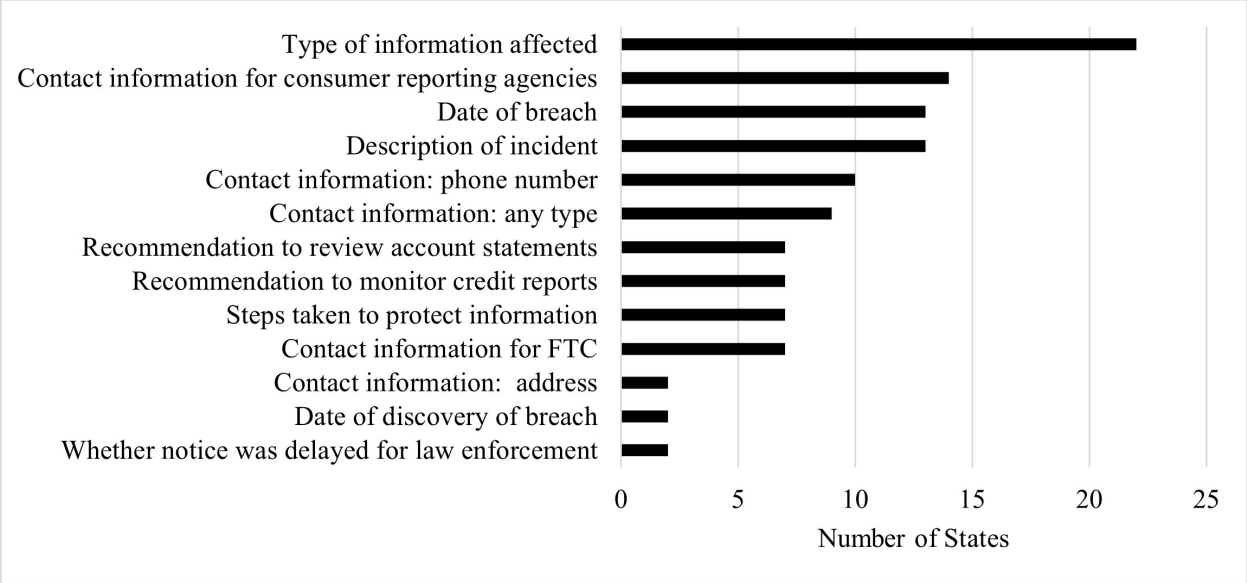


Figure 4: Frequency of different items required by state laws to be included in the notices to affected individuals. Date source: State law in 2023.

States also differ in their requirements regarding the method that must be used to notify affected individuals.[562] While all states allow for a written notification, most states impose conditions if the notice is sent electronically. For example, 37 states provide that a notice can be sent electronically only if the notice is consistent with the Electronic Signatures in Global and National Commerce Act.[563] Fifteen states have as a condition that a primary method of communication between the entity and the affected residents be by electronic means.[564] Five states impose no condition for electronic notices,[565] and 2 states only require that the notifying

[562] We conducted this supplemental analysis to help analyze and respond to comments, and also to provide additional context for our analysis of the possible effects of the final amendments. *See infra* section IV.D.1.b(5).

[563] 15 U.S.C. 7001, et seq. *See, e.g.*, Cal. Civ. Code § 1798.82(j); Conn. Stat. § 36a-701b.(e); Ga. Code § 10-1-911(4); Tex. Bus. & Com. Code § 521.053(e).

[564] *See. e.g.*, Colo. Rev. Stat. § 6-1-716(1)(F); Del. Code Tit. 6 § 12B-101(5); Tenn. Code Ann. § 47-18-2107(e).

[565] *See, e.g.*, Ala. Code § 8-38-5(d); Fla. Stat. § 501.171(4)(d); Va. Code. Ann. § 18.2-186.6(A).